

Development of a Reference Application for the OWASP Mobile Application Security Testing Guide (MASTG)

BACHELOR'S THESIS
Dominic Kronig

Universität Bern
Bern, November 12, 2025



First Reviewer: **Prof. Dr. Vorname Name**
 Universität XY
 Institut XY

Second Reviewer: **Vorname Name**
 Universität XY
 Institut XY

Abstract: The OWASP Mobile Application Security project is the industry standard when it comes to android mobile application security. It comprises all aspects of mobile application security, from documenting weaknesses to providing verification standards. Part of it is the Mobile Application Security Testing Guide (MASTG), which gives detailed instructions on how to thoroughly test mobile applications. Complementing the MASTG are so called "reference apps", which serve as a source of learning in the form of including intentionally built in weaknesses, which can be found and exploited using the MASTG, as to teaching mobile developers what to avoid in their own applications. This BA thesis aims to evaluate the state of the art of said reference apps, conduct a literature review on the relevancy and usage of the MASTG and related OWASP fields in the academic world, as well as develop a new MASTG reference app. This reference app includes both dynamic and static vulnerabilities and documents each vulnerability thoroughly, including where it can be found in the code, how to exploit it, and how to fix it.

Contents

1	Introduction	1
1.1	Section	2
1.1.1	SubSection	2
2	Related Work	3
2.1	State-Of-The-Art in OWASP MASTG Reference Apps	3
2.1.1	Findings	3
2.2	Literature Review - Academic relevance of OWASP MASTG	7
	List of Figures	9
	Bibliography	11

1 Introduction

Start writing here 1...

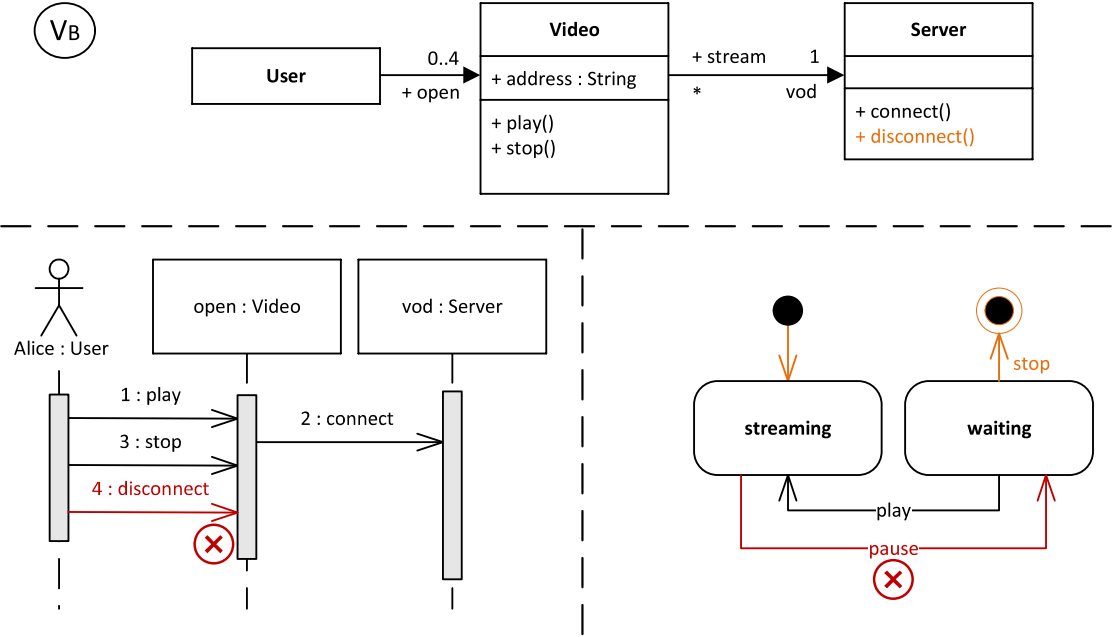


Figure 1.1: Figure description here

Figure 2.3

Reference example [1]

- one
- two

1. one
2. two

In Definition 1.1...

Definition 1.1

$$e = mc^2$$

Lemma 1.0.1

$$e = mc^2$$

Proof. $e = mc^2$

□

Requirement 1.0.1

$$e = mc^2$$

Example 1.0.1

$$e = mc^2$$

```
1 // Hello.java
2 import java.awt.Graphics;
3 public class Hello extends JApplet {}
```

Algorithmus 1.1: foo

```
1 function helloWorld(in name) {}
```

Algorithmus 1.2: foo

SOME NOTE

(TODO: HERE A TODO!)

1.1 Section

1.1.1 SubSection

SubSubSection

Pragraph

SubPragraph

2 Related Work

There are two types of related work for this BA thesis. The first consists of already existing OWASP MASTG reference apps for android. The second is about academic works making use of the MASTG, an industry standard, and its reference apps.

2.1 State-Of-The-Art in OWASP MASTG Reference Apps

At the time of writing, there are currently 19 MASTG reference apps listed on the OWASP page. To evaluate the state of the art of these apps, it is necessary to examine each one of them in order to identify and categorize their implemented weaknesses. Only 8 of said apps had both available sourcecode as well as some form of documentation of their weaknesses. These were then mapped by the author to their corresponding OWASP MASWE counterparts.

2.1.1 Findings

Across the 8 evaluated OWASP MASTG reference apps, 162 weaknesses were mapped to their respective MASWE counterpart and grouped by their vulnerability category (Storage, Crypto, Auth, etc.).

Lack of vulnerability documentation

A reoccurring issue with many of the reference apps is their documentation of the implemented vulnerabilities. Multiple of the reference apps do not have any documentation of their weaknesses at all, which led to their exclusion from this evaluation. Those apps that do have some form of documentation are often incomplete, and almost always only consist of a single list, naming the implemented weaknesses and leaving it at that. None of the apps map the implemented weaknesses to their OWASP MASWE counterparts, despite them being a MASTG reference app, designed for this very purpose. Only one app ([TODO: add source and specific names of mentioned apps here, just in general less vague than](#)

is now.) actually documents what the weaknesses entail, how they are implemented, and how to fix or exploit them.

Since these apps are meant by OWASP to be educational, it does not suffice to only implement the weaknesses and leave as is. The app developed in this BA thesis aims to fill this hole by not only documenting all implemented weaknesses, but adding documentation for each specific weakness, consisting of where it is found, what lines of code are of relevancy, how to exploit them, aswell as how to fix them.

Uneven distribution of vulnerability coverage

At the time of writing, there are a total of 117 MASWE vulnerabilities across 8 categories documented by OWASP. Of these 117 vulnerabilities, only 38 are actually covered by any of these reference apps.

(TODO: CREATE GRAPH DISPLAYING VULNERABILITY COVERAGE GROUPED BY APP, INSERT HERE) Since there are 162 weaknesses implemented, but only 38 different types of weaknesses as used by the MASTG, this leaves a total of 79 vulnerabilities, as documented and classified by OWASP MASWE and referenced in the MASTG, completely without representation. This further means that there are some vulnerabilities which are heavily favoured to be implemented in these reference apps, with them being added in high frequency, while many more vulnerabilities see no coverage at all.

To make this point more clear; the ten most frequently covered vulnerabilities are in total implemented 75 times, meaning that they represent 46% (75/162) of all implemented vulnerabilities, despite only covering 8.5% (10/117) vulnerabilities as referenced by MASTG. The most frequently implemented vulnerability, as seen in Figure 1, is MASWE-0066, which deals with insecure intents. Of the ten most frequently covered vulnerabilities, 5 are of the category "Platform".

Coverage of vulnerability categories

There is not only a favouring of certain specific MASWE vulnerabilities, but also an uneven coverage of the vulnerability categories themselves as well. When viewed percentage-wise, as seen in figure 2.2., some categories see a high percentage of their vulnerabilities covered, such as Platform with 72.7% or Storage with 66.7%, while others see very little to no coverage at all, such as both Crypto and Auth with only 10% and worst of all Privacy with a vulnerability coverage of 0%.

Viewing the coverage in absolute rather than percentage values makes it look a lot more un-even. As seen in Figure 2.3, all categories have 2 to 6 types of vulnerability

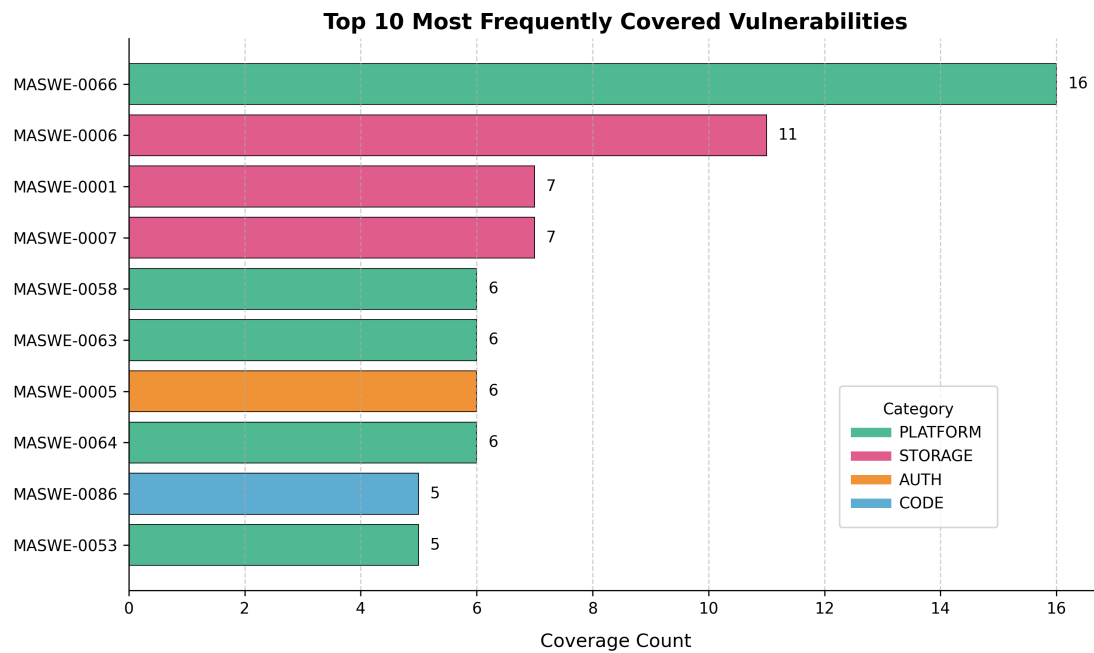


Figure 2.1: Barplot depicting the ten most frequently covered types of OWASP MASWE vulnerabilities, colored according to their respective category.

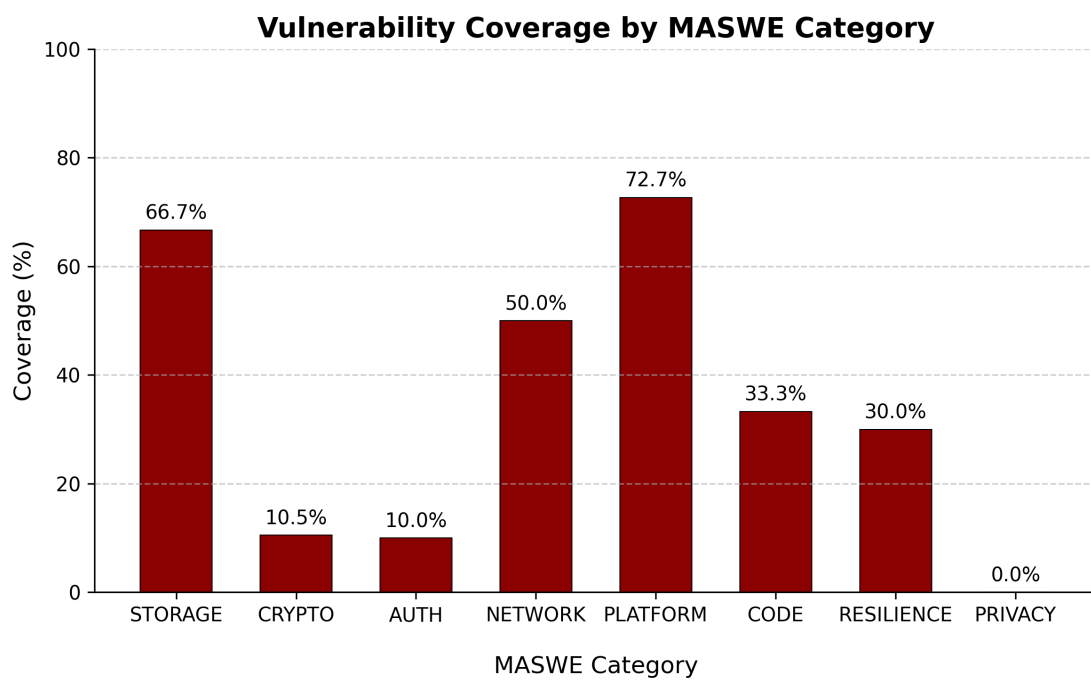


Figure 2.2: (TODO: ADD IMAGE CAPTION)

types covered, with the only outliers being the category Platform, which has a total of 16 of 22 vulnerabilities implemented, and Privacy, which has no vulnerabilities at all covered. This shows that vulnerabilities are covered rather evenly across the 8 categories, regardless of the amount of vulnerabilities each category has, which explains the large differences in percentage-wise coverage as seen in the previous Figure 2.2.

The remarkably high coverage of Platform vulnerabilities further enforces the findings of Figure 2.1, meaning that not only are 5 of the 10 most frequently covered vulnerabilities of type Platform, the category itself is also the most broadly implemented category when compared to others. The complete lack of coverage of Privacy vulnerabilities can in part be accounted for by the fact that the category itself is newer than the other 7, only having been introduced in MASVS version 2.1.0. (TODO: ADD SOURCE HERE). Also, the vulnerabilities as described in Privacy are partly more abstract in nature, not necessarily being implementable in the code itself, such as "MASWE-0111: Inadequate Privacy Policy".

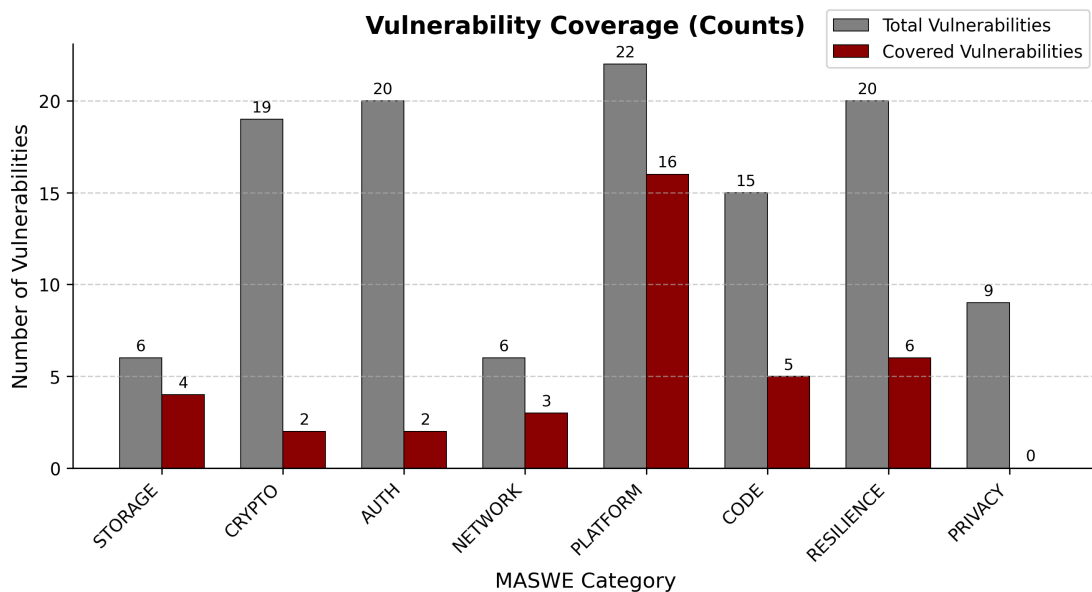


Figure 2.3: (TODO: ADD IMAGE CAPTION)

Nevertheless, it can be concluded that the categories are un-evenly covered, with Platform receiving a great deal more of attention than the other categories, and Privacy receiving none. Also, it is clear that the coverage of many categories in these state-of-the-art reference apps is lacking, with only a concerning 10% of all Crypto and Auth vulnerabilities, as documented by MASWE and tested by MASTG, actually being cov-

ered. This despite both of these categories being of great importance, and making up a large part of what mobile security as conducted by OWASP deals with, considering they make up a third (33%) of all vulnerabilities as documented by MASWE and tested by MASTG.

The reference app developed in this BA thesis aims to solve this issue, by covering the vulnerabilities more broadly, and shifting the focus from over-favoured Categories such as Platform to more neglected ones, such as Crypto and Auth.

2.2 Literature Review - Academic relevance of OWASP MASTG

The OWASP MASTG is the industry standard for mobile app security. But what relevancy does it have in the academic world, and what exactly is it used for? To answer this question, a literature review was conducted, to evaluate papers on their use of the OWASP MASTG, as well as related OWASP parts, e.g. the MASTG reference apps, the MASWE and the MASVS.

List of Figures

- 1.1 Figure description here 1
- 2.1 Barplot depicting the ten most frequently covered types of OWASP MASWE vulnerabilities, colored according to their respective category. 5
- 2.2 (TODO: ADD IMAGE CAPTION) 5
- 2.3 (TODO: ADD IMAGE CAPTION) 6

Bibliography

- [1] T. Arendt, E. Biermann, S. Jurack, C. Krause, and G. Taentzer, “Henshin: advanced concepts and tools for in-place emf model transformations,” *Model Driven Engineering Languages and Systems*, pp. 121–135, 2010.

Erklärung

gemäss Art. 30 RSL Phil.-nat.18

Name/Vorname:

Matrikelnummer:

Studiengang:

Bachelor ☐

Master ☐

Dissertation ☐

Titel der Arbeit:

LeiterIn der Arbeit:

Ich erkläre hiermit, dass ich diese Arbeit selbständig verfasst und keine anderen als die angegebenen Quellen benutzt habe. Alle Stellen, die wörtlich oder sinngemäss aus Quellen entnommen wurden, habe ich als solche gekennzeichnet. Mir ist bekannt, dass andernfalls der Senat gemäss Artikel 36 Absatz 1 Buchstabe r des Gesetzes vom 5. September 1996 über die Universität zum Entzug des auf Grund dieser Arbeit verliehenen Titels berechtigt ist.

Für die Zwecke der Begutachtung und der Überprüfung der Einhaltung der Selbständigkeitserklärung bzw. der Reglemente betreffend Plagiate erteile ich der Universität Bern das Recht, die dazu erforderlichen Personendaten zu bearbeiten und Nutzungshandlungen vorzunehmen, insbesondere die schriftliche Arbeit zu vervielfältigen und dauerhaft in einer Datenbank zu speichern sowie diese zur Überprüfung von Arbeiten Dritter zu verwenden oder hierzu zur Verfügung zu stellen.

Ort/Datum

Unterschrift

